

Supporting Document

Evaluation Activities for collaborative PP-Module for Database-as-a-Service (DBaaS)

Version 0.4, 2026-06-30

Table of Contents

1. Revision History	1
2. Introduction	2
2.1. Technology Area and Scope of Supporting Document	2
2.2. Managed-Service Evaluation Constraint	2
2.3. Relationship to Other Documents	3
3. General Guidance for Evaluators	4
3.1. Verifying the Trusted Platform	4
3.2. TOE, TOE Platform, and Trusted Platform Boundary Enumeration	4
3.3. Evaluator Access Strategy	5
3.4. Tenant Isolation Testing Strategy	5
3.5. External Service Dependencies	5
4. FCS Class: Cryptographic Support	6
4.1. FCS_CKM_DBAAS_EXT.1 Customer-Controlled Keys	6
4.1.1. Evaluation Activities	6
4.1.1.1. TSS Activities	6
4.1.1.2. Guidance Activities	6
4.1.1.3. Test Activities	7
5. FDP Class: User Data Protection	8
5.1. FDP_RIP.1/DBaaS Residual Information Protection	8
5.1.1. Evaluation Activities	8
5.1.1.1. TSS Activities	8
5.1.1.2. Test Activities	8
5.2. FDP_ACC.2/DBaaS Tenant Isolation Policy	8
5.2.1. Evaluation Activities	8
5.2.1.1. TSS Activities	8
5.2.1.2. Test Activities	9
5.3. FDP_ACF.1/DBaaS Tenant Isolation Policy Rules	9
5.3.1. Evaluation Activities	9
5.3.1.1. TSS Activities	9
5.3.1.2. Guidance Activities	9
5.3.1.3. Test Activities	9
5.4. FDP_BKP_EXT.1 Protected Backup and Restore	10
5.4.1. Evaluation Activities	10
5.4.1.1. TSS Activities	10
5.4.1.2. Guidance Activities	11
5.4.1.3. Test Activities	11
6. FRU Class: Resource Utilisation	12
6.1. FRU_RSA.1/DBaaS and FRU_RSG_EXT.1 Resource Governance	12

6.1.1. Evaluation Activities	12
6.1.1.1. TSS Activities	12
6.1.1.2. Guidance Activities	12
6.1.1.3. Test Activities	12
7. FIA Class: Identification and Authentication	14
7.1. FIA_USB.1/DBaaS User-Subject Binding	14
7.1.1. Evaluation Activities	14
7.1.1.1. TSS Activities	14
7.1.1.2. Test Activities	14
8. FMT Class: Security Management	15
8.1. FMT_SMR.1/DBaaS Security Roles	15
8.1.1. Evaluation Activities	15
8.1.1.1. TSS Activities	15
8.1.1.2. Guidance Activities	15
8.1.1.3. Test Activities	15
8.2. FMT_SMF.1/DBaaS Specification of Management Functions	15
8.2.1. Evaluation Activities	15
8.2.1.1. TSS Activities	15
8.2.1.2. Guidance Activities	16
8.2.1.3. Test Activities	16
8.3. FMT_MOF.1/DBaaS-Disable and FMT_MOF.1/DBaaS-Modify Management of Security Functions Behaviour	16
8.3.1. Evaluation Activities	16
8.3.1.1. TSS Activities	16
8.3.1.2. Guidance Activities	16
8.3.1.3. Test Activities	16
9. FAU Class: Security Audit	18
9.1. FAU_SEL.1/DBaaS Selective Audit	18
9.1.1. Evaluation Activities	18
9.1.1.1. TSS Activities	18
9.1.1.2. Test Activities	18
9.2. FAU_STG.2/DBaaS Protected Audit Trail Storage (Immutable Audit Stream)	18
9.2.1. Evaluation Activities	18
9.2.1.1. TSS Activities	18
9.2.1.2. Guidance Activities	18
9.2.1.3. Test Activities	19
10. FPT Class: Protection of the TSF	20
10.1. FPT_TUD_DBAAS_EXT.1 Autonomous Trusted Update	20
10.1.1. Evaluation Activities	20
10.1.1.1. TSS Activities	20
10.1.1.2. Guidance Activities	20

10.1.1.3. Test Activities	20
Appendix A: Document References	22

Chapter 1. Revision History

Table 1. Revision history

Version	Date	Description
0.1	2026-01-25	Initial draft of Evaluation Activities for DBaaS deployments.
0.2	2026-05-14	Aligned the SD with the CCiTC SaaS evaluation model: added the managed-service evaluation constraint, trusted-platform evidence handling, tenant-interface testing strategy, and per-SFR Evaluation Activities.
0.3	2026-06-30	Aligned with the v0.3 PP-Module: renamed iterated Base PP components to /DBaaS, added Evaluation Activities for FMT_SMR.1/DBaaS, FMT_SMF.1/DBaaS, and FDP_BKP_EXT.1, added explicit TOE/Platform/Trusted-Platform boundary enumeration guidance, and aligned references with cPP_DBMS Version 2.0 and the DBMS Cryptographic Functions Module Version 0.3. This SD remains in draft and is expected to mature on a later schedule than the Cloud and Crypto Module SDs.
0.4	2026-06-30	Refocused the FDP_BKP_EXT.1 Evaluation Activities on provider-plaintext-restore prevention and restore tenant-binding, with data-at-rest confidentiality of backups evaluated under the DBMS Cryptographic Functions Module SD. Version aligned with the v0.4 module and SD set.
0.4	2026-07-07	Managed-Service Evaluation Constraint contrast sentence updated: tenant-operated deployments cover both cloud-native and lift-and-shift models.
0.4	2026-07-07	Aligned SD sections with the module's component changes: resource governance activities moved to an FRU class section covering FRU_RSA.1/DBaaS and FRU_RSG_EXT.1; FIA_USB.1/DBaaS; FMT_MOF.1/DBaaS-Disable and -Modify; FAU_STG.2/DBaaS; FAU_SEL.1/DBaaS audit-query scoping noted as evaluated under FDP_ACF.1/DBaaS.
0.4	2026-07-08	Renamed the FPT_TUD_EXT.2 section to FPT_TUD_DBAAS_EXT.1 following the module's family rename.

Chapter 2. Introduction

2.1. Technology Area and Scope of Supporting Document

This Supporting Document (SD) defines Evaluation Activities (EAs) for the **collaborative PP-Module for Database-as-a-Service** (DBMS_MOD_DBAAS), version 0.4. The technology area addressed is a Database Management System (DBMS) offered as a managed Database-as-a-Service, in which the cloud service provider operates and manages the DBMS on behalf of tenants.

This SD provides Evaluation Activities that evaluators shall perform to determine whether a TOE satisfies the Security Functional Requirements (SFRs) specified in the DBaaS PP-Module. These activities complement the Evaluation Activities defined in the Supporting Document for the collaborative Protection Profile for Database Management Systems (cPP_DBMS SD), which remains applicable for all SFRs inherited from the Base PP, and the Supporting Document for the DBMS Cryptographic Functions Module, which provides cryptographic, data-at-rest, data-in-transit, and key-management Evaluation Activities.

The Evaluation Activities in this SD are derived from the Common Evaluation Methodology (CEM:2022) work units and are aligned with the CCiTC Guidance for Cloud Evaluations Software-as-a-Service (SaaS) model.

2.2. Managed-Service Evaluation Constraint

Unlike a tenant-operated cloud deployment (cloud-native or lift-and-shift), the DBaaS TOE is a provider-operated managed service. The evaluator typically does not have access to:

- the underlying operating system;
- the hypervisor or physical hardware;
- raw process memory;
- provider operational tooling; or
- Service Provider administrative accounts.

Evaluation Activities in this SD are therefore designed to be performed through:

1. **Tenant interfaces:** standard SQL clients, tenant-facing web consoles, APIs, audit views, and management interfaces accessible to the customer.
2. **Documentation review:** analysis of the ST, TSS, operational guidance, and provider architecture descriptions.
3. **Scheme-accepted evidence:** cloud authorization, certification, scheme policy, or other evidence accepted by the applicable evaluation scheme for Trusted Platform assumptions and operational environment objectives.

2.3. Relationship to Other Documents

This SD is used in conjunction with:

- **cPP_DBMS SD**, Version 2.0: Evaluation Activities for SFRs inherited from the Base PP.
- **DBMS Cryptographic Functions Module SD**, Version 0.4: cryptographic, data-at-rest, data-in-transit, key-management, and algorithm-validation Evaluation Activities.
- **DBaaS PP-Module**, version 0.4: requirements definition.

Where SFRs are iterated by the PP-Module as **/DBaaS**, the Evaluation Activities in this SD supplement those in the Base PP SD for the tenant-scoped refinements.

Chapter 3. General Guidance for Evaluators

3.1. Verifying the Trusted Platform

The evaluator shall review the ST and operational guidance to identify the Trusted Platform relied upon by the TOE. The evaluator shall verify that the ST identifies the cloud authorization, certification, scheme policy, or other evidence submitted to support the Trusted Platform assumptions and Operational Environment objectives. The evaluator shall confirm that the stated scope of the evidence covers the identified Cloud Service Offering, region, services, and evaluated configuration, and shall document this reliance in the ETR.

The evaluation authority determines whether the submitted evidence is acceptable under the applicable scheme policy, including recognized authorization programs, assurance levels, currency, and exceptions. The evaluator does not independently establish Trusted Platform acceptance criteria or treat cloud authorization evidence as satisfying a TOE SFR unless the applicable requirement expressly permits use of a platform-provided mechanism.

3.2. TOE, TOE Platform, and Trusted Platform Boundary Enumeration

Because a DBaaS architecture may allocate components and supporting services differently, the evaluator shall confirm that the boundary between TOE-enforced behavior and platform-provided properties is explicitly enumerated and is consistent with all claimed SFRs, assumptions, and Operational Environment objectives. Provider ownership or operation of a component does not by itself determine its allocation.

The evaluator shall:

1. Verify that the TSS enumerates, for each claimed SFR, the security behavior performed by the TOE and any supporting property relied upon from the TOE Platform, Trusted Platform, or another operational environment component.
2. Verify that a claimed SFR is not allocated wholly to the Trusted Platform or operational environment unless the applicable requirement expressly permits use of a platform-provided mechanism. Where such use is permitted, verify that the TSS distinguishes the evaluated TSF behavior from the external property on which it relies.
3. For each external reliance, verify that the allocation is supported by operational guidance and is linked to an assumption or Operational Environment objective. Where the TOE behavior at the boundary is testable through tenant-accessible interfaces, apply the relevant test activities in this SD.
4. Record in the ETR each external reliance, the applicable assumption or Operational Environment objective, the identified evidence, and the applicable scheme policy or acceptance decision.

This enumeration is the primary mechanism by which the TOE/Trusted-Platform boundary is made explicit and evaluable; the per-SFR TSS activities below compel the enumeration, and the test

activities verify it wherever the evaluated configuration permits.

3.3. Evaluator Access Strategy

The evaluator shall identify the interfaces available in the evaluated configuration and map each test to one or more tenant-accessible or provider-supported evaluation interfaces. When a direct test is not feasible because the function is outside the TOE boundary or requires provider-only access, the evaluator shall determine whether the SD permits reliance on TSS review, operational guidance, scheme-accepted evidence, or a provider-supported demonstration.

3.4. Tenant Isolation Testing Strategy

Testing for logical isolation requires the evaluator to provision at least two distinct tenant contexts, such as separate tenants, databases, pluggable databases, schemas, namespaces, or accounts, depending on the ST claim. The evaluator shall attempt cross-tenant access through the same interfaces available to the tenant in the evaluated configuration.

The evaluator shall avoid relying on undocumented provider privileges as primary test mechanisms unless those privileges are part of the evaluated configuration or are used only to set up or observe the test under controlled conditions.

3.5. External Service Dependencies

When the TOE relies on external key management, identity provider, logging, object storage, backup, management, or trusted time services, the evaluator shall verify that the ST identifies:

- whether the service is part of the TOE, TOE Platform, Trusted Platform, or operational environment;
- which SFRs, assumptions, and operational environment objectives depend on the service;
- what evidence supports the service's claimed security properties; and
- which operational guidance configures the service for the evaluated configuration.

Chapter 4. FCS Class: Cryptographic Support

4.1. FCS_CKM_DBAAS_EXT.1 Customer-Controlled Keys

4.1.1. Evaluation Activities

4.1.1.1. TSS Activities

The evaluator shall verify the TSS describes:

- the customer-controlled key management architecture;
- the supported customer-controlled key models, such as BYOK, HYOK, external KMS integration, key references, or key handles;
- the boundary between TOE key-management logic and external key management services;
- the protocols and authentication mechanisms used for external key management service access, including the trusted channel specified by the DBMS Cryptographic Functions Module and applicable Functional Packages;
- whether plaintext customer-controlled master key material is imported into, stored by, cached by, wrapped by, transformed by, or re-exported by the TOE;
- how the TOE prevents service provider administrators from viewing, exporting, recovering, or otherwise obtaining plaintext customer-controlled master key material through TOE interfaces;
- the applicable DBMS-specific and Catalogue-derived components included through the DBMS Cryptographic Functions Module for key import, key wrapping, key destruction, and data-at-rest encryption, together with Functional Package components for trusted channels; and
- the TOE behavior when authorization to use the applicable customer-controlled master key is revoked, unavailable, or denied.

If the TOE caches key material, key handles, or derived keys after successful KMS authorization, the evaluator shall verify that the TSS identifies the cache duration, protection mechanism, revocation behavior, and conditions under which cached material is invalidated.

4.1.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes:

- how a customer configures customer-controlled keys for the TOE;
- how a customer revokes or disables the TOE's authorization to use an external key;
- expected TOE behavior after key authorization is revoked, unavailable, or denied;
- any documented recovery mechanism that permits protected data access after revocation; and
- any customer-visible audit or status information related to key use, key failures, or key authorization.

4.1.1.3. Test Activities

Test 1: Provider Inaccessibility Verification

1. Configure the TOE to use a customer-controlled master key or external key reference as described in the operational guidance.
2. Access protected database data as an authorized tenant user or tenant administrator.
3. Verify that access succeeds.
4. Attempt to export, view, recover, or display the plaintext master key material through each tenant-facing DBMS interface and management interface available in the evaluated configuration.
5. Verify that each attempt is denied or that the interface exposes only non-sensitive key identifiers, references, status, or metadata.

Test 2: Key Revocation Behavior

1. Configure the TOE to use an external customer-controlled key or key authorization mechanism.
2. Access protected database data as an authorized tenant user or tenant administrator.
3. Revoke, disable, or deny the TOE's authorization to use the external key according to the operational guidance.
4. Attempt to access protected database data in the TOE.
5. Verify that access is denied, except for data available through an explicitly documented and evaluated recovery mechanism.

If the TOE caches key material, key handles, or derived keys after successful KMS authorization, the evaluator shall test that revocation of the TOE's authorization to use the external key prevents access to protected data no later than the expiration of the documented cache interval.

Test 3: Key Material Handling Evidence

1. Review audit records, status views, error messages, diagnostic outputs, backup metadata, and management outputs that are tenant-accessible in the evaluated configuration.
2. Verify that plaintext customer-controlled master key material is not disclosed.
3. If provider-supported observation is used for non-tenant-accessible diagnostics, verify that the observation method and results are documented in the ETR.

Chapter 5. FDP Class: User Data Protection

5.1. FDP_RIP.1/DBaaS Residual Information Protection

5.1.1. Evaluation Activities

5.1.1.1. TSS Activities

The evaluator shall review the TSS to determine whether tenant data can be present in shared DBMS memory, buffer cache, temporary storage, query work areas, diagnostic structures, or other shared DBMS resources. The evaluator shall verify that the TSS describes how such resources are cleared, reinitialized, or access-controlled before allocation to another tenant.

The evaluator shall verify that the TSS identifies which residual information protections are implemented by the TOE and which are provided by the TOE Platform, Trusted Platform, or operational environment.

5.1.1.2. Test Activities

Test 1: Tenant-Interface Residual Data Test

1. Provision two tenant contexts in the evaluated configuration.
2. As Tenant A, create data with a unique pattern unlikely to appear elsewhere in the system.
3. Exercise TOE functionality that places the data into the claimed shared resource, such as queries that use buffer cache, temporary storage, sort areas, or query work areas.
4. Release the resource using documented tenant operations, such as dropping temporary objects, closing sessions, purging objects, or completing the workload.
5. As Tenant B, use documented tenant interfaces to allocate comparable resources and attempt to observe Tenant A's unique pattern.
6. Verify that Tenant B cannot observe Tenant A's data through tenant-accessible interfaces.

Where tenant-accessible interfaces permit repeatable testing, the evaluator shall perform the test through those interfaces. The evaluator is not required to inspect raw process memory unless such access is available in the evaluated configuration and permitted by the test environment.

5.2. FDP_ACC.2/DBaaS Tenant Isolation Policy

5.2.1. Evaluation Activities

5.2.1.1. TSS Activities

The evaluator shall verify the TSS identifies the subjects, objects, and operations covered by the Tenant Isolation SFP. The evaluator shall verify that the TSS identifies the tenant boundary used by the TOE, such as tenants, databases, pluggable databases, schemas, namespaces, accounts, tablespaces, tenant identifiers, or other DBMS constructs.

5.2.1.2. Test Activities

The test activities for FDP_ACC.2/DBaaS are performed with the FDP_ACF.1/DBaaS tenant isolation policy rule tests.

5.3. FDP_ACF.1/DBaaS Tenant Isolation Policy Rules

5.3.1. Evaluation Activities

5.3.1.1. TSS Activities

The evaluator shall verify the TSS describes:

- the security attributes used to enforce the Tenant Isolation SFP, including tenant identifier, user identifier, service role, object owner, object tenant identifier, object type, and operation;
- how tenant subjects are bound to tenant identifiers;
- how tenant data objects, tenant metadata objects, and tenant audit records are labeled, scoped, or otherwise associated with tenant identifiers;
- the treatment of global system metadata visible to multiple tenants;
- any evaluated cross-tenant sharing mechanism and the authorization model for that mechanism; and
- how service provider administrative subjects are restricted from tenant data access except through interfaces and roles explicitly identified in the ST.

5.3.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes how tenant boundaries are provisioned, how tenant users and service accounts are associated with tenant identifiers, and how any evaluated cross-tenant sharing mechanism is configured and revoked.

5.3.1.3. Test Activities

Test 1: Data Cross-Access Prevention

1. Provision Tenant A and Tenant B in the evaluated configuration.
2. Create tenant data objects in Tenant A with names and values known to the evaluator.
3. As Tenant B, attempt to access Tenant A's objects through documented SQL, API, management, import/export, backup, restore, and tenant administration interfaces available in the evaluated configuration.
4. Verify that all unauthorized attempts fail.

Test 2: Metadata Isolation

1. As Tenant A, create objects with distinct names.
2. As Tenant B, query system catalogs, metadata views, information schema views, management APIs, search interfaces, and monitoring views available to tenants.

3. Verify that Tenant B sees only Tenant B metadata and metadata explicitly defined as global system metadata.

Test 3: Tenant Audit Record Isolation

1. Generate audit events in Tenant A and Tenant B.
2. As Tenant A, query tenant-accessible audit records.
3. Verify that only Tenant A audit records are returned unless an evaluated provider, cross-tenant, or compliance function explicitly authorizes broader access.
4. Verify that Tenant B-specific usernames, object names, query text, or tenant data are not visible to Tenant A through tenant audit interfaces.

Test 4: Evaluated Cross-Tenant Sharing

If the ST claims an evaluated cross-tenant sharing mechanism:

1. Configure sharing between Tenant A and Tenant B according to the operational guidance.
2. Verify that Tenant B can access only the shared objects, metadata, or records authorized by Tenant A or by the evaluated sharing policy.
3. Revoke the sharing authorization.
4. Verify that Tenant B can no longer access the previously shared objects, metadata, or records.

5.4. FDP_BKP_EXT.1 Protected Backup and Restore

5.4.1. Evaluation Activities

5.4.1.1. TSS Activities

The evaluator shall verify the TSS describes:

- the backup and restore architecture for protected tenant data, including whether backups are created, stored, and restored by the TOE, the TOE Platform, or an external backup or object storage service;
- the reliance on **FDP_DAR_EXT.1** of the DBMS Cryptographic Functions Module for the data-at-rest protection of backup data (this SD does not retest data-at-rest protection, which is covered by the DBMS Cryptographic Functions Module SD);
- how the TOE prevents a service provider administrator from restoring or exporting protected tenant data in plaintext without authorized use of the applicable customer-controlled master key; and
- how restored tenant data is bound to the originating tenant identifier so that a restore does not place data outside the Tenant Isolation SFP.

If backup storage or restore orchestration is provided by an external service, the evaluator shall verify the TSS identifies whether the restore authorization and tenant binding are TOE functionality or are addressed by OE.EXTERNAL_SERVICES; the data-at-rest protection of externally stored backups is assessed under **FDP_DAR_EXT.1**.

5.4.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes how backups are configured, how restore is authorized, the roles permitted to perform restore, and any customer-visible status or audit information for backup and restore operations.

5.4.1.3. Test Activities

Note: The data-at-rest confidentiality of backup data is evaluated under **FDP_DAR_EXT.1** of the DBMS Cryptographic Functions Module SD and is not retested here. The activities below address the backup and restore-path properties specific to this module.

Test 1: Provider Plaintext Restore Prevention

1. As a Service Provider Administrator role, or the closest role available in the evaluated configuration, attempt to restore or export Tenant A protected data in plaintext without authorized use of the customer-controlled key.
2. Verify that the operation is denied or that the restored data remains encrypted under the customer-controlled key.

Test 2: Restore Tenant Binding

1. Restore a Tenant A backup according to the operational guidance.
2. As Tenant B, attempt to access the restored Tenant A data.
3. Verify that restored data remains within the Tenant A isolation boundary and is not accessible to Tenant B.

Chapter 6. FRU Class: Resource Utilisation

6.1. FRU_RSA.1/DBaaS and FRU_RSG_EXT.1 Resource Governance

The activities below address the quota enforcement required by [FRU_RSA.1/DBaaS](#) and the enforcement action required by [FRU_RSG_EXT.1](#) together, as they are exercised by the same workloads.

6.1.1. Evaluation Activities

6.1.1.1. TSS Activities

The evaluator shall verify the TSS describes:

- the DBMS-managed resources subject to tenant quotas or limits (the completion of the [FRU_RSA.1.1/DBaaS](#) selection);
- the resource governance mechanism, such as resource managers, quotas, workload queues, throttling, session limits, or query governors;
- the enforcement action claimed in [FRU_RSG_EXT.1.1](#) for operations that exceed configured limits;
- the authorized roles that can configure resource governance; and
- how resource governance is applied to tenants, users, service accounts, and workloads.

6.1.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes how to configure tenant resource limits and how to monitor quota enforcement.

6.1.1.3. Test Activities

Test 1: Resource Limit Enforcement

1. Configure a resource quota for a tenant according to the operational guidance.
2. Initiate a workload that exceeds the configured limit.
3. Verify that the TOE performs the enforcement action claimed in [FRU_RSG_EXT.1.1](#), such as queueing, throttling, rejection, or termination.
4. Verify that the TOE remains available for other tenant operations that do not exceed their configured limits.

Test 2: Unauthorized Resource Governance Modification

1. Authenticate as a role that is not authorized to modify resource governance settings.
2. Attempt to increase or disable the tenant resource quota.

3. Verify that the operation is denied.

Chapter 7. FIA Class: Identification and Authentication

7.1. FIA_USB.1/DBaaS User-Subject Binding

7.1.1. Evaluation Activities

7.1.1.1. TSS Activities

The evaluator shall verify the TSS describes how tenant identifier, user identifier, and service role attributes are associated with subjects acting on behalf of users or service accounts, and how the TOE prevents tenant-controlled inputs from changing the bound tenant identifier except through an evaluated mechanism.

7.1.1.2. Test Activities

Test 1: Tenant ID Binding Verification

1. Authenticate as a tenant user.
2. Execute a documented query or API call that returns the current tenant context, session attributes, or equivalent DBMS context.
3. Verify that the returned tenant identifier matches the authenticated tenant.
4. Attempt to change the tenant identifier by using user-controlled session parameters, connection attributes, request headers, or SQL variables that are available to the tenant.
5. Verify that unauthorized tenant identifier changes are denied or ignored.

Test 2: Audit Correlation

1. Perform an auditable action as Tenant A.
2. Query the audit trail through tenant-accessible interfaces.
3. Verify that the audit record is stamped with the correct tenant identifier and user identifier.
4. Authenticate as Tenant B.
5. Attempt to access the Tenant A audit record.
6. Verify that Tenant B cannot access the Tenant A audit record unless an evaluated sharing or compliance function explicitly permits access.

Chapter 8. FMT Class: Security Management

8.1. FMT_SMR.1/DBaaS Security Roles

8.1.1. Evaluation Activities

8.1.1.1. TSS Activities

The evaluator shall verify the TSS identifies the roles maintained by the TOE, including Tenant User, Tenant Administrator, Service Provider Administrator, and any automated autonomous management logic or other roles claimed in the ST. The evaluator shall verify the TSS describes how users and service accounts are associated with these roles and how the roles map to the management restrictions in the [FMT_MOF.1/DBaaS](#) iterations and the access-control rules in [FDP_ACF.1/DBaaS](#).

8.1.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes how each role is assigned, the privileges associated with each role, and the separation between Tenant Administrator and Service Provider Administrator capabilities.

8.1.1.3. Test Activities

Test 1: Role Maintenance and Association

1. Using the interfaces available in the evaluated configuration, enumerate the roles recognized by the TOE.
2. Verify that the roles claimed in the ST are present.
3. Associate a test user with a tenant role and verify that the user receives the privileges defined for that role and no others.

8.2. FMT_SMF.1/DBaaS Specification of Management Functions

8.2.1. Evaluation Activities

8.2.1.1. TSS Activities

The evaluator shall verify the TSS identifies the management functions provided by the TOE, including configuration of customer-controlled key references and key-management integration, tenant resource quotas, audit export and retention, and any evaluated cross-tenant sharing mechanism. The evaluator shall verify the TSS identifies, for each management function, the authorized roles defined by [FMT_SMR.1/DBaaS](#).

8.2.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes how to perform each claimed management function and which role is authorized to perform it.

8.2.1.3. Test Activities

Test 1: Management Function Availability

1. For each claimed management function, perform the function as an authorized role using the interfaces available in the evaluated configuration.
2. Verify that the function operates as described.
3. Attempt the same function as an unauthorized role and verify that it is denied. This test may be performed jointly with the **FMT_MOF.1/DBaaS** iteration tests.

8.3. FMT_MOF.1/DBaaS-Disable and FMT_MOF.1/DBaaS-Modify Management of Security Functions Behaviour

8.3.1. Evaluation Activities

8.3.1.1. TSS Activities

The evaluator shall verify the TSS identifies the security functions that cannot be disabled in the evaluated configuration (**FMT_MOF.1/DBaaS-Disable**) and the roles authorized to modify DBaaS security functions such as resource governance, patching and updates, and audit export (**FMT_MOF.1/DBaaS-Modify**).

8.3.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes the roles authorized to modify each claimed DBaaS security function and the expected behavior when unauthorized roles attempt modification.

8.3.1.3. Test Activities

Test 1: Audit Immutability Control

1. Authenticate as a tenant administrator.
2. Attempt to disable audit generation for TOE-required audit events.
3. Verify that the operation is denied.

Test 2: Encryption Immutability Control

1. Authenticate as a tenant administrator.
2. Attempt to disable data-at-rest encryption for protected tenant data.
3. Verify that the operation is denied.

Test 3: Role Restriction Verification

1. Authenticate as a tenant administrator or other role not authorized to manage provider or root-level functions.
2. Attempt to grant provider, root, or equivalent administrative privileges to a standard tenant user.
3. Verify that the operation is denied.

Chapter 9. FAU Class: Security Audit

9.1. FAU_SEL.1/DBaaS Selective Audit

9.1.1. Evaluation Activities

9.1.1.1. TSS Activities

The evaluator shall verify the TSS describes how audit event selection is scoped by tenant identifier, user identifier, service role, object identifier, and event type. Restriction of audit record queries to the owning tenant is an access-control rule of FDP_ACF.1/DBaaS and is evaluated there; Test 1 below may be performed jointly with the FDP_ACF.1/DBaaS tests.

9.1.1.2. Test Activities

Test 1: Audit Scope Leakage

1. Generate audit events in Tenant A and Tenant B.
2. As Tenant A administrator, query the audit logs.
3. Verify that only Tenant A records are returned unless an evaluated provider, cross-tenant, or compliance function explicitly authorizes broader access.
4. Analyze the query results to ensure no Tenant B data, usernames, object names, query text, or tenant identifiers are visible to Tenant A unless explicitly authorized by the evaluated configuration.

9.2. FAU_STG.2/DBaaS Protected Audit Trail Storage (Immutable Audit Stream)

9.2.1. Evaluation Activities

9.2.1.1. TSS Activities

The evaluator shall verify the TSS describes how the TOE prevents unauthorised modification and deletion of stored audit records, including that no tenant-facing interface provides audit modification or deletion functions. If audit records are exported to an external sink, the evaluator shall verify the TSS identifies whether the export mechanism, external sink, or both are part of the TOE or operational environment.

9.2.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes audit retention, audit export configuration, authorized audit query roles, and any recovery or archival mechanism for audit records.

9.2.1.3. Test Activities

Test 1: Deletion and Modification Prevention

1. As a tenant administrator, identify an audit record generated by the TOE.
2. Attempt to delete or modify that record through documented tenant interfaces, such as SQL DELETE or UPDATE commands, management APIs, or tenant audit tools.
3. Verify that the operation is denied.

Test 2: Audit Export Verification

1. Configure audit export to an external sink according to the operational guidance.
2. Generate audit events.
3. Verify that the external sink receives the expected events.
4. Attempt to stop, redirect, or weaken the audit export pipeline as a tenant administrator.
5. Verify that the unauthorized operation is denied.

Chapter 10. FPT Class: Protection of the TSF

10.1. FPT_TUD_DBAAS_EXT.1 Autonomous Trusted Update

10.1.1. Evaluation Activities

10.1.1.1. TSS Activities

The evaluator shall verify the TSS describes:

- the autonomous or provider-managed update mechanism;
- how the update source is authenticated;
- how update package authenticity and integrity are verified before installation, with reference to the **FCS_COP.1/SigVer** component included through the DBMS Cryptographic Functions Module;
- whether updates are applied automatically, through provider-managed orchestration, or according to a documented maintenance schedule; and
- whether update orchestration is included in the TOE or provided by the TOE Platform, Trusted Platform, or operational environment.

10.1.1.2. Guidance Activities

The evaluator shall verify the operational guidance describes customer-visible update status, update windows or deferral options if supported, and any tenant-visible configuration related to updates.

10.1.1.3. Test Activities

Note: Testing live patching in a production DBaaS environment can be disruptive. Testing should be conducted on a non-production instance when possible, or verified through provider-supported demonstration, audit logs, and documentation when live update execution is not appropriate for the evaluated configuration.

Test 1: Update Provenance

1. Review audit logs, system event logs, update status views, or provider-supported evidence for a recent patch application.
2. Verify that the evidence identifies the update source.
3. Verify that the evidence indicates authenticity and integrity verification of the update package, if such logging is claimed in the TSS.

Test 2: Tenant Non-Interference

1. Authenticate as a tenant administrator.

2. Attempt to block, bypass, or indefinitely delay security patches using tenant-accessible configuration settings.
3. Verify that security patches are applied according to the evaluated provider or TOE update policy, not unauthorized tenant policy.

Appendix A: Document References

- [CC1] Common Criteria for Information Technology Security Evaluation, Part 1: Introduction and general model, CCMB-2022-11-001, CC:2022 Revision 1, November 2022.
- [CC2] Common Criteria for Information Technology Security Evaluation, Part 2: Security functional requirements, CCMB-2022-11-002, CC:2022 Revision 1, November 2022.
- [CC3] Common Criteria for Information Technology Security Evaluation, Part 3: Security assurance requirements, CCMB-2022-11-003, CC:2022 Revision 1, November 2022.
- [CC4] Common Criteria for Information Technology Security Evaluation, Part 4: Framework for the specification of evaluation methods and activities, CCMB-2022-11-004, CC:2022 Revision 1, November 2022.
- [CC5] Common Criteria for Information Technology Security Evaluation, Part 5: Pre-defined packages of security requirements, CCMB-2022-11-005, CC:2022 Revision 1, November 2022.
- [CCE] Common Criteria for Information Technology Security Evaluation, Errata and interpretation for CC:2022 (Release 1) and CEM:2022 (Release 1), CCMB-002, Version 1.1, July 22, 2024.
- [CEM] Common Methodology for Information Technology Security Evaluation, Evaluation methodology, CCMB-2022-11-006, CEM:2022 Revision 1, November 2022.
- [DBMS_MOD_DBAAS] collaborative PP-Module for Database-as-a-Service (DBaaS), Version 0.4, 2026-06-30.
- [cPP_DBMS] collaborative Protection Profile for Database Management Systems, Version 2.0, 27 April 2026.
- [cPP_DBMS_SD] Supporting Document Mandatory Technical Document Evaluation Activities for the collaborative Protection Profile for Database Management Systems, Version 2.0, 27 April 2026.
- [DBMS_MOD_CRYPTOP] collaborative PP-Module for DBMS Cryptographic Functions, Version 0.4, 2026-06-30.
- [DBMS_MOD_CRYPTOP_SD] Supporting Document - Evaluation Activities for DBMS Cryptographic Functions Module, Version 0.4, 2026-06-30.
- [Crypto_Catalog] Specification of Functional Requirements for Cryptography (CCDB-018), Version 1.0, January 2025.
- [TLS_FP] Functional Package for Transport Layer Security (TLS), Version 2.1, 2025-08-25.
- [CCiTC_SaaS] Common Criteria in the Cloud Technical Community, Guidance for Cloud Evaluations, Version 1.1.